Handoff 05: Backlog, feature plans and feedback security (stage 5)

Date: 2026-10-25 (America/Toronto)
Written by: Claude Code (implementer)
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: pull request open, not merged. **Documentation only**: no application code, content, database, settings or deployment changed.

> **How to use this file:** upload it with `build.md`, `docs/plan/backlog.md`, `docs/plan/course-catalog.md` (sections 9, 11 and 12) and `docs/plan/feedback-security.md`. The pull request diff is the source of truth (`build.md` section 14).

Starter prompt for the chat assistant

```
You are reviewing Python Academy stage 5, which is documentation only:
a reconciled backlog, two proposed features (testers/feedback/admin inbox,
and end-of-unit skill checks), and a security plan for feedback. I'm
attaching build.md, the backlog, the plan, the security plan and this
handoff. Check that the backlog IDs follow build.md, that the owner's
decisions are recorded exactly, and that every feedback threat has a
server-side control. Look for anything that would weaken the anonymity
the owner asked for, and for contradictions between the documents.
Explain at a first-year computer engineering level.
```

1. Where we are

Stage	What	Status
1–3	Content format, migrations and ledgers, catalog UI	Merged and verified live (PRs #5, #7, #8)
4	Goals and recommendations	Merged (PR #9, 2026-10-25); owner's live check not yet recorded
5	Backlog, feature plans, feedback security	**in_review**: this PR

2. Handoff record (build.md template)

Field	Value
Task	Stage 5: add the owner's backlog, reconcile it with `build.md`, record decisions, plan two features, write the feedback threat model
Human goal	One ordered list of work everyone follows, and safe, agreed designs for feedback and unit checks before any code is written
Repository and branch	`torontojohn/python-academy`, branch `docs/stage-5-backlog`
Base commit	`a74ef0f` (`main` after PR #9)
Deployment status	Not applicable (documentation only); not merged

Files changed

File	Change
`docs/plan/backlog.md`	New. The owner's backlog, moved from `docs/handoffs/backlog.md` and reconciled with `build.md` (section 8 of the file lists every change)
`build.md`	Section 13 links the backlog and says it is the source of truth for the order of work, while IDs and their meanings stay defined in `build.md`. Section 2 lists the new documents
`docs/plan/course-catalog.md`	Owner decisions 11, 12, 13, 18 and 21 recorded in section 9; the "unit complete" rule in section 4.2 now includes the unit check; new sections 11 (testers, feedback, admin inbox) and 12 (end-of-unit checks); status and session record updated
`docs/plan/feedback-security.md`	New. Each threat with its server-side controls and tests, plus the trade-offs of anonymous feedback

Owner decisions recorded (2026-10-25)

#	Decision
11	The feedback button is for testers only
12	Feedback is stored anonymously. Sign-in is required only to stop bots; no user ID, name or email is saved with feedback
18	Feedback is deleted 50 days after creation at the latest; the inbox holds at most 90 items. When full, the oldest resolved items are deleted first; if none are resolved, the new item is rejected with a clear message
13	Unit checks are required to complete a unit, and learners can retake them
21	Each check has variants by a self-chosen learner level (high school, university). Never collect a birthdate for this

Still open, as asked, and tracked in `docs/plan/backlog.md` section 6: 14 (admin identity), 15 (pass rule), 16 (check versus unit project), 17 (optional code), 19 (parents never see feedback), 20 (capstone per goal).

ID conflicts with build.md, and how they were resolved

`build.md` was followed in every case.

#	Conflict	Resolution
1	**OPS-01**: "reduce Render costs" in the backlog; "confirm staging, recovery, privacy, quotas and alerts" in `build.md`	OPS-01 keeps the `build.md` meaning and priority (Before broad rollout); OPS-02 to OPS-04 marked as parts of it; cost review moved to new **OPS-05**
2	**EDU-01**: "optional skills check for placement", Later, in the backlog; "write placement question/task examples", Next, in `build.md`	`build.md` wording and priority; building the check is **EDU-02**
3	**EDU-02 / EDU-03** missing; the backlog's **EDU-05** (unit 3 loops) is `build.md`'s EDU-03	EDU-02 added; unit 3 renamed EDU-03 (priority "After checker design"); EDU-05 marked unused; EDU-06 now depends on EDU-03
4	**TOOL-01**: the full Git course, Later, in the backlog; "Git versus GitHub and first commit lessons", Alongside projects, in `build.md`	`build.md` wording and priority; full course is new **TOOL-02**
5	**ID-01**: Later in the backlog; Next in `build.md`	Next
6	**QA-01**: accessibility only in the backlog; `build.md` includes grading reports	`build.md` scope; QA-02 marked as part of QA-01
7	**WEB-01 / DATA-01 / NODE-01 / CE-01**: one row, "build the courses"; `build.md` has four design or planning tasks	Split into four rows with the `build.md` meanings
8	**PLAN-01, PLAN-02, ENG-01, ENG-02** missing from the backlog	Added with status and evidence
9	**ENG-02** shown as verified; `build.md`'s ENG-02 also covers skill evidence, progress records and retention	Stage 2 stays verified; ENG-02 itself is in_progress
10	**Decisions 1–10** in the backlog reused the numbers of the plan's decisions 1–10, which mean different things	Renumbered 11–20 and all references updated; new decision 21 for learner level
11	**FB-08** used "Dropped", which is not a `build.md` priority or status	Priority "—", status deferred
12	**Stage 4** marked "confirm merge"	PR #9 is merged; stays in_review until the live check is recorded

Acceptance criteria

- Backlog added as `docs/plan/backlog.md`, every ID checked, conflicts resolved in favour of `build.md` and listed. **Met.**

- `build.md` links the backlog as the source of truth for ordering. **Met.**
- Two features added to the plan, and the five owner decisions recorded exactly; the others left open. **Met.**
- Feedback threat model covering admin takeover, stored XSS, spam and bots, optional code, personal details, CSRF, and counters without message text, with the trade-offs of anonymity. **Met.**
- No application code changed; nothing merged. **Met.**

Checks run

- `git diff --stat origin/main` touches only `build.md`, `docs/plan/` and `docs/handoffs/`.
- Every relative link in the new and changed documents resolves to an existing file.
- Every backlog ID that appears in `build.md` section 13 now has the same meaning and priority in the backlog.
- Statements about current code in the security plan (the Origin check middleware, cookie flags, account-history events) were checked against `backend/app/main.py`.
- No tests were run, because no code changed; CI still runs on the pull request.

Things found while writing the security plan

- **Account history:** the app records every important action, with the user's ID and exact time, in the account history (`events` table). If feedback were recorded there the same way, the sender would be identifiable. The plan requires that feedback is never written there, with a test.
- **Hosting logs:** Render's own request logs record IP addresses and times. Someone with log access could match a submission to a person; the app cannot prevent this. The plan says to describe feedback as "sent without your name or email", not "untraceable".
- **Copy digest:** the digest sends text to an outside assistant, so code is excluded by default and the admin reviews it first.
- **GitHub issue link field:** this is a possible `javascript:` link attack; the plan restricts it to this repository's issue and pull request URLs.

3. Questions for the owner

1. **Birthdate.** Decision 21 says never collect a birthdate, but enrolment already asks for a date of birth for the existing age rules (students 13 or older, parents over 25). I recorded it as: the learner level is self-chosen and never derived from, or asks for, a birthdate; the age gate stays as it is. Is that what you meant, or do you want the enrolment date of birth reconsidered (an account-policy change)?
2. **Unit XP.** Plan section 6.1 gives 200 XP for passing a unit project. If the unit check also awards "the unit XP" and the project stays (proposed decision 16), which one earns the 200, or is it split?
3. **Unit 1.** It has no check yet. When checks become required, do learners who already completed unit 1 keep it as complete?
4. **"Resolved"** for the 90-item cap: I proposed `fixed` and `wont_fix`. Agreed?
5. **SEC-03** (logout revokes the session) is Later in your backlog, but the security plan needs it before the admin inbox ships. Move it to Next?

6. **Who can be a tester?** The backlog says students. Should parents, or the maintainer's own account, be able to be testers too?
7. **OPS-05 reminder for 2026-11-08.** The backlog says a reminder is set. I did not set one. Is it on your side, or should I schedule one?
8. **PLAN-01** asks for a milestone owner. Who should be recorded?

4. Next concrete action

Owner reviews this PR and answers the questions. Then, following the backlog order: record the stage 4 live check, then SEC-01 and SEC-04.